

Федеральное государственное автономное
образовательное учреждение высшего образования
«Национальный исследовательский университет ИТМО»

Информационная безопасность

Работа №4

«Анализ уязвимостей веб-приложения с помощью OWASP ZAP»

Болорболд Аригуун

Группа: P3411

Выполнение

Сканирование было выполнено используя встроенного функционала OWASP ZAP, точнее режим запуска «Quick Scan» для URL <http://testphp.vulnweb.com/>. Приложение выполнило разведку данного веб-сайта путём расследования его структуры и активного сканирования на наличие широкоизвестных уязвимостей. В итоге был получен подробный отчёт как показано на рисунке 1, содержащий 17 различных типов проблем:

- Критический: 1
- Средний: 4
- Низкий: 5
- Информационные: 7,

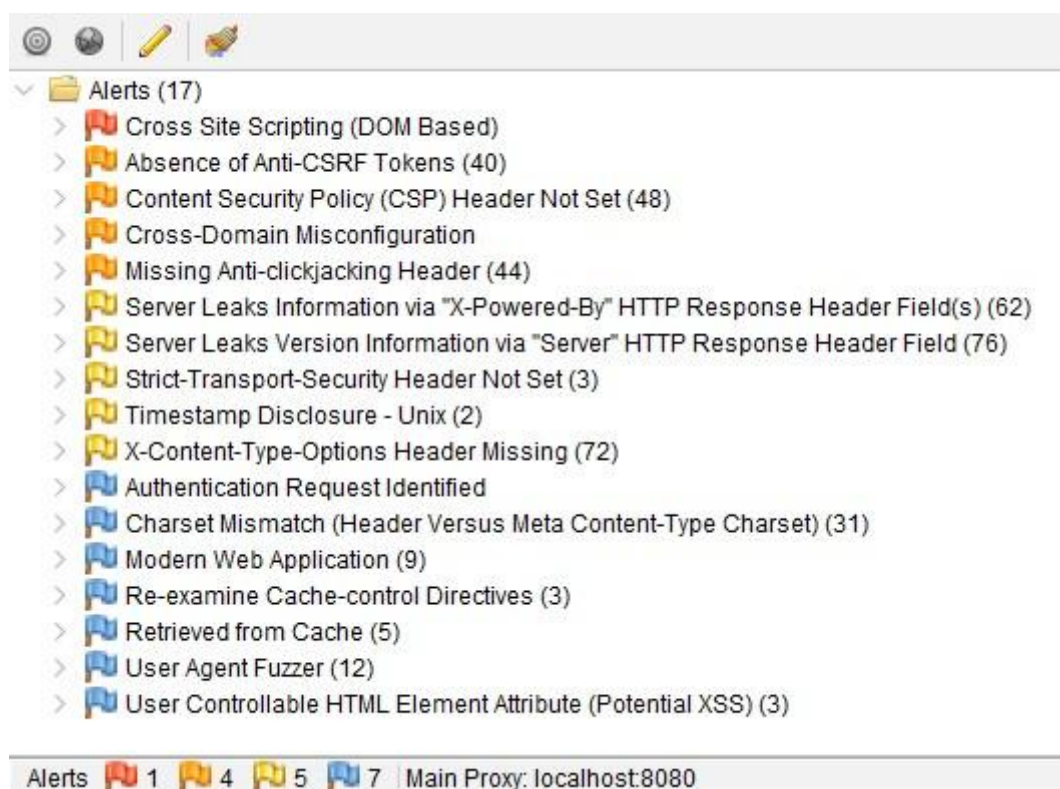


Рисунок 1 — Предупреждения ZAP

Далее представлены 5 наиболее критичных типов уязвимостей, обнаруженных в ходе проверки с подробным описанием их сути и потенциального воздействия.

Уязвимость 1: Межсайтовый скриптинг (Cross Site Scripting)

Уровень риска: Высокий (High), количество экземпляров: 1.

Это вид уязвимости, который позволяет злоумышленнику внедрять вредоносный код на веб-страницу. Является следствием неаккуратной обработки данных от злоумышленника или выполнения скрипта из возвращенной сервером модифицированной страницы клиентским JavaScriptом. В отчёте, как показано на рисунке 2, есть успешное выполнение следующей полезной нагрузки:

```
(jaVaScRipt:/*-  
/*`/*\`/*'/*"*/ (**/oNcliCk=alert(5397))//%0D%0A%0d%0a//</stYle/</ti  
tLe/</teXtarEa/</scRipt/--!>\x3csVg/<sVg/oNlOad=alert(5397)//>\x3e)
```

которая вызвала появление всплывающего окна, что подтверждает возможность выполнения любого кода.

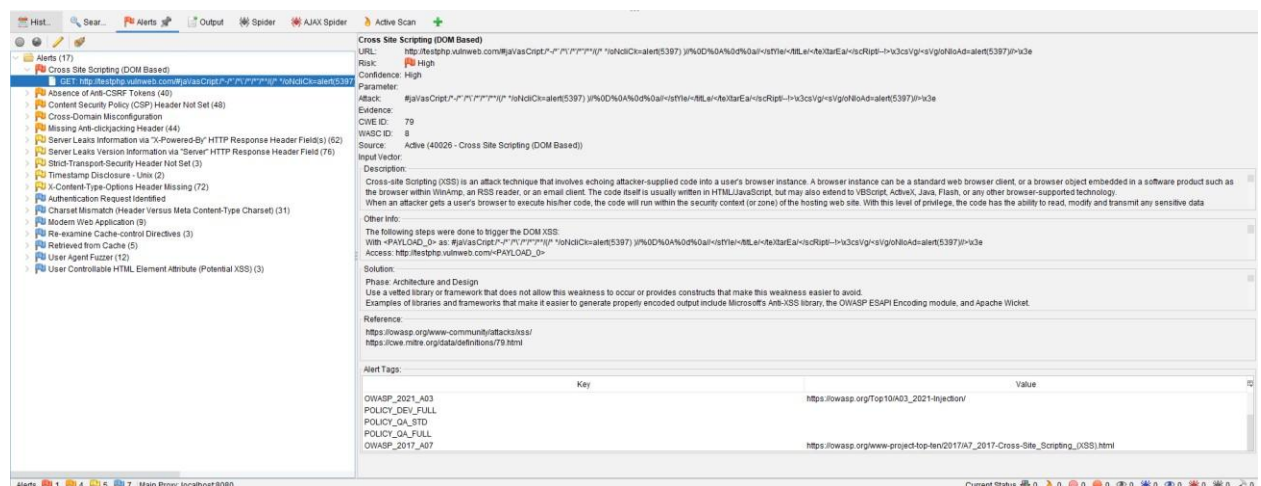


Рисунок 2 — Найденная ZAP уязвимость межсайтового скриптинга на основе DOM

Это дает злоумышленнику возможность перенаправления жертвы в фишинговый сайт, кражи сессионных куки или выполнения любых действий от его имени.

Уязвимость 2: Отсутствие токенов защиты от CSRF (Absence of Anti-CSRF Tokens)

Уровень риска: Средний, количество экземпляров: 40.

Уязвимость CSRF (Cross-Site Request Forgery, подделка межсайтовых запросов) дает злоумышленнику возможность заставить уже аутентифицированного пользователя выполнить нежелательное действие на вебсайте, на котором он вошел в систему. В ZAP показано, что в формах вовсе отсутствуют скрытые поля с уникальными токенами (например, *CSRFToken* или *anticsrf*), а это означает, что злоумышленник может создавать поддельную веб-страницу, которая с свою очередь отправит POST-запросы на целевой сайт, а браузер жертвы будет выполнить его, так как POST-запросы будут сопровождаться действительными сессионными куки. Отчёт об обнаружении данной уязвимости, включая и нескрытых HTML-форм, показан на рисунке 3.

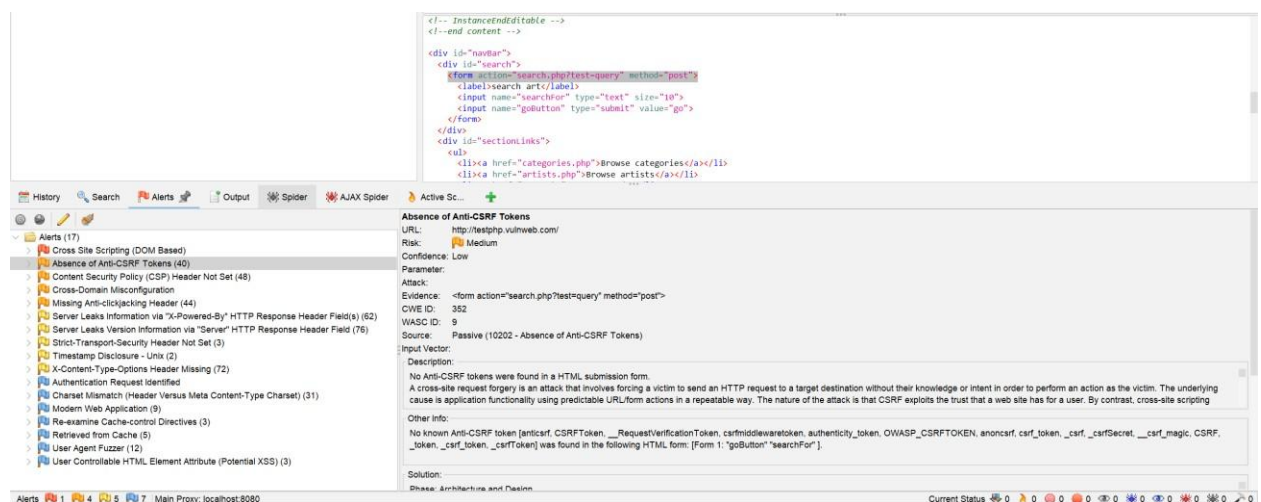


Рисунок 3 — Отсутствие токенов Anti-CSRF в формах

Это дает злоумышленнику возможность выполнить различные действия от имени жертвы, начиная от изменения пароли и отправки сообщений до перевода денег и более серьёзных нарушений.

Уязвимость 3: Отсутствие заголовки политики безопасности контента (Content Security Policy (CSP) Header Not Set)

Уровень риска: Средний, количество экземпляров: 48.

Данная уязвимость означает, что веб-сервер не отправил браузеру заголовок «Content-Security-Policy», который сообщает браузеру, какие ресурсы (то есть скрипты, стили, мультимедиа и т.д.) ему разрешено загружать. Это в свою очередь предотвращает такие атаки, как например XSS и инъекции данных. Однако без такого заголовка (можно загрузить всё) браузер может загрузить и выполнить нежелательного ресурса, как например вредоносного скрипта. Отчёт расследования ZAP показан на рисунке 4.

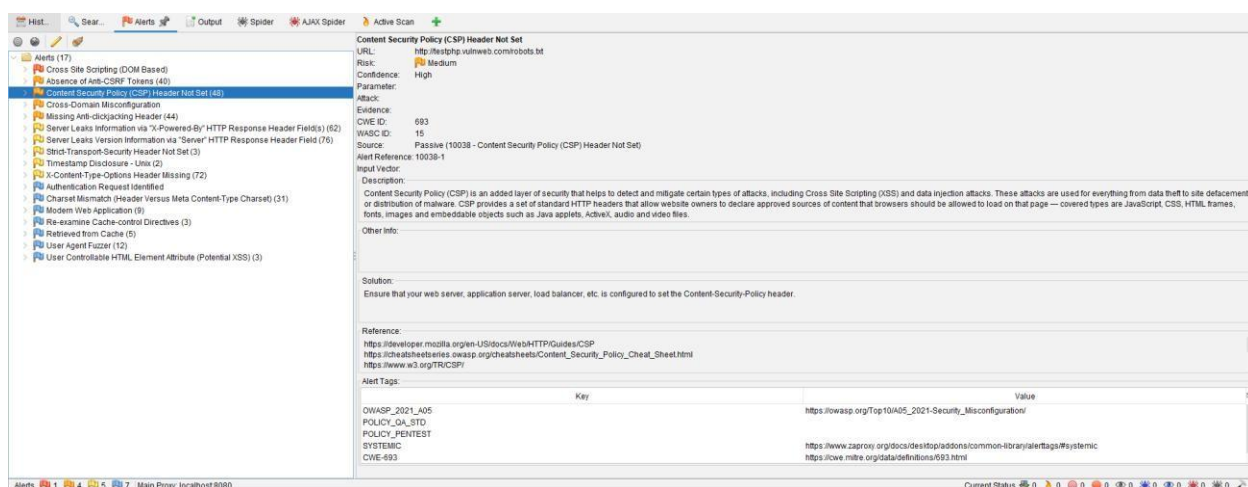


Рисунок 4 — Отсутствие заголовки политики безопасности контента

Это позволяет злоумышленнику совершить много чего, включая, но не ограничиваясь: кражу данных, разрушение и вандализм веб-сайта, распространение вредоносных ПО.

Уязвимость 4: Ошибка междоменной конфигурации (Cross-Domain Misconfiguration)

Уровень риска: Средний, количество экземпляров: 1.

Эта уязвимость представляет из себя некорректной настройки безопасности при обмене данными между различными доменами. Обычно браузеры блокируют запросы между разными доменами из-за «политики одинакового источника» (Same-Origin Policy), чтобы предотвратить потенциальную кражу данных, но с помощью политики CORS (Cross-Origin Resource Sharing) можно обойти этого ограничения. Проблема появится, когда эти конфигурации настроены неправильно (например, *Access-Control-Allow-Origin: **, который разрешает доступ всем доменам), а это разрешает злоумышленникам «бить» по целевому веб-сайту. Отчёт расследования ZAP показан на рисунке 5.

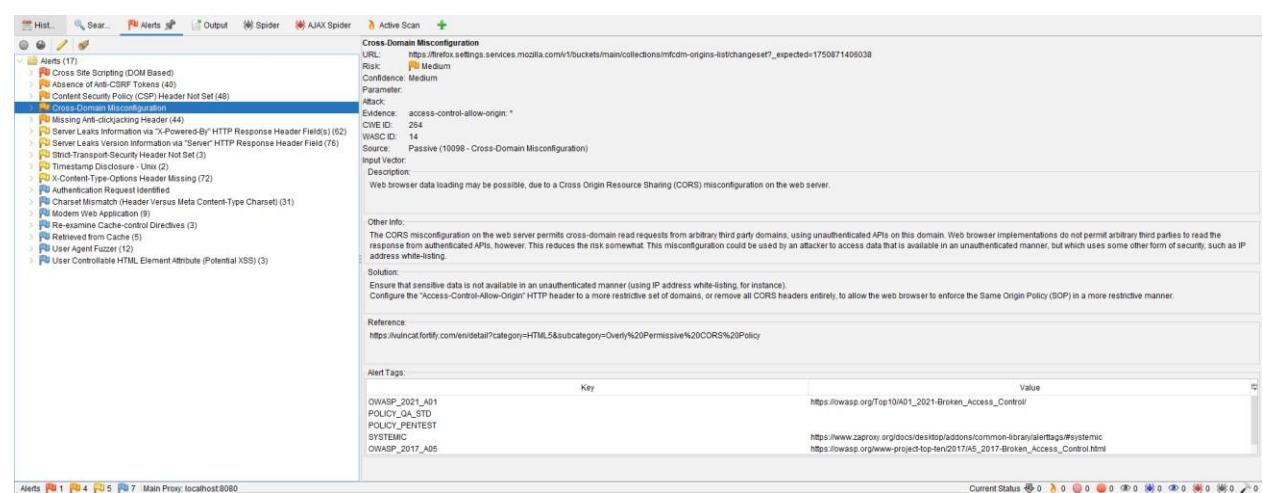


Рисунок 5 — Неосторожная настройка политики CORS

Это ведет к таким последствиям, как отправка вредоносных запросов, несанкционированный доступ, перехват сессии, утечка чувствительных данных и т.д.

Уязвимость 5: Отсутствие заголовки против кликджекинга (Missing Anti-clickjacking Header)

Уровень риска: Средний, количество экземпляров: 44.

Этот вид уязвимости представляет из себя отсутствия заголовков безопасности (*X-Frame-Options*, *Content-Security-Policy*), нацеленных против «кликджекинга». Это такая техника, когда злоумышленники обманом заставляют пользователя нажать на что-то, но на самом деле пользователь нажимает на невидимого вредоносного элемента (обычно это *iframe*), наложенный поверх легитимной веб-страницы. На рисунке 6 в отчётах как раз показано отсутствие этих заголовков в запросах, которые контролируют, может ли страница быть встроена в *<iframe>* на других сайтах.

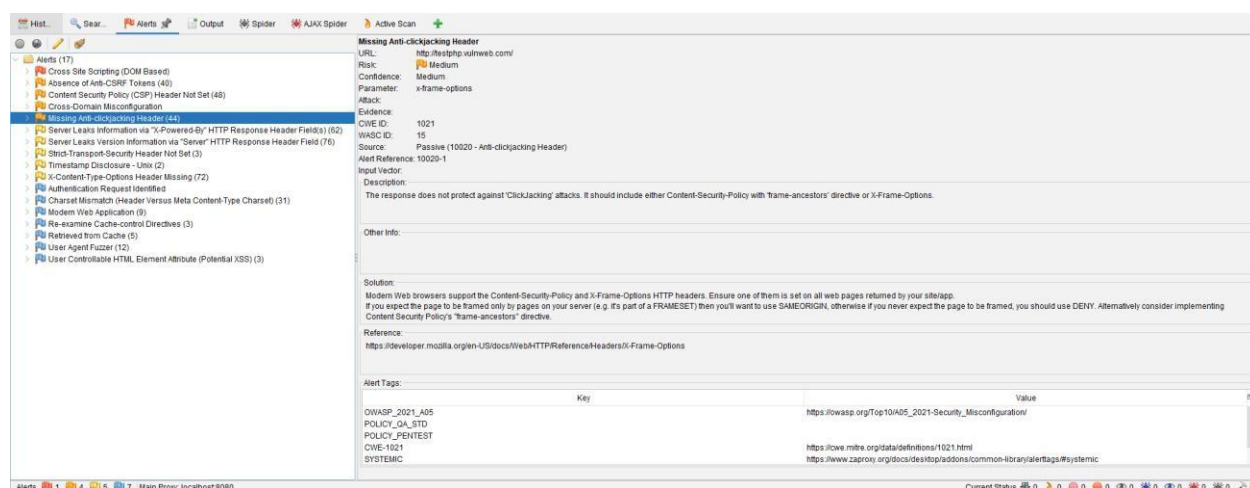


Рисунок 6 — Отсутствие заголовков против «кликджекинга»

Это дает злоумышленнику возможность перенаправить жертву куда угодно, от фишинговых сайтов до скачивания вредоносных ПО на устройстве.